

MedSeal — полный анализ проекта

National AI Hackathon, Наманган 2026 · трек «Медицина» · официальная задача №6 · состояние на 25.09.2026 (ветки main и backend, коммит 713e4d2 + локальные изменения)

Вывод. Платформа работает от начала до конца: печать, проверка, ИИ-щит, ИИ-детектив, краш-тест, паспорт модели с PDF и веб-интерфейс на трёх языках. Все 76 автотестов проходят, печать и проверка — около 2 мс. Слабые места: тепловая карта детектива (4,8% попаданий), отсутствие авторизации в API, веса детектива не в репозитории и сетевой доступ с других устройств на площадке.

1. Готовность по частям

Часть	Статус	Ключевой показатель	Комментарий
Печать (Seal)	✓ готово	1,5 мс (PNG 512 ²), 3,8 мс (DICOM 1024 ²)	Ed25519 + дерево Меркла, формат хеша заморожен тестом
Проверка (Verify)	✓ готово	1,8 мс, точность до тайла 32×32	4 статуса, причина для forged
Реестр (hash-chain)	✓ готово	проверка целостности /ledger/check	подмена записи → forged
ИИ-щит	✓ готово	100% PGD при eps ≥ 1, 0,9% ложных тревог	откалиброван на 450 снимках NIH
ИИ-детектив	! частично	AUC 0,942, точность 88%	тепловая карта ненадёжна, скрыта в UI
Краш-тест	✓ готово	50 снимков PGD ≈ 80 с, оценка 0,2/10	фоновые задачи, прогресс
Паспорт + PDF	✓ готово	вердикт по правилам, PDF uz/ru	замораживается при выдаче
Frontend	✓ готово	7 страниц, uz/ru/en, спецвозможности	подключён к реальному API
Регистрация	! только UI	форма физ./юр. лица	без backend: данные никуда не сохраняются
Демо-данные	! частично	подделки для детектива и щита есть	tampered-файл делается скриптом после печати
Доступ по сети	! зависит от сети	настроено на IP 10.178.233.180	в сети площадки возможна изоляция устройств

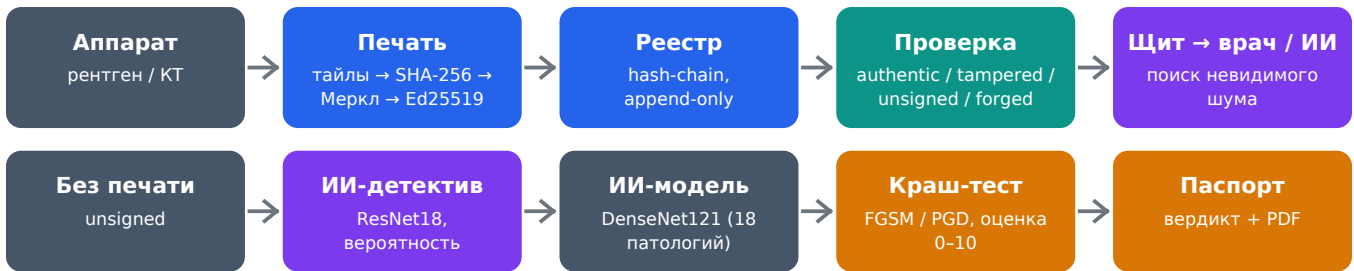
2. Задача и решение

Проблема. Медицинский снимок — обычный файл: его можно подделать (дорисовать или стереть находку), а ИИ, который его читает, можно обмануть невидимым шумом. Задача №6 хакатона требует стандартов этики и безопасности ИИ для рентгена и КТ.

Решение MedSeal — «печать и антивирус» для снимков: криптографическая печать в момент съёмки даёт точный ответ о подлинности, а три ИИ-модуля закрывают то, что печать не покрывает: снимки без печати (детектив), атаки на ИИ (щит) и оценку самой модели (краш-тест → паспорт). Паспорт модели и есть предлагаемый стандарт.

3. Архитектура

Поток снимка (сверху) и поток модели (снизу):



Слой	Технологии
Backend	Python 3.14, FastAPI, SQLAlchemy + SQLite, cryptography (Ed25519), pydicom, Pillow, fpdf2
ИИ	PyTorch (CPU), torchxrayvision DenseNet121, torchvision ResNet18, OpenCV — без GPU и облака
Frontend	Next.js 16 (App Router), React 19, TypeScript, Tailwind 4; словарь uz/ru/en
Данные	NIH ChestX-ray14 (CC0, 2500 взрослых снимков), Kermany (CC BY 4.0, детские) — только открытые

4. Как работает каждая часть

4.1 Печать и проверка — криптография, не ИИ

- Снимок делится на тайлы 32×32 (16×16 для маленьких). Хеш тайла: SHA-256 от «uid|y|x|форма|тип» + сырые пиксели в исходном типе (int16 у КТ не приводится к 8 битам).
- Листья сортируются по (y, x) → корень дерева Меркла → подпись Ed25519 ключом устройства (root + uid).
- PNG получает uid в текстовом блоке medseal_uid (пиксели не меняются); у DICOM uid = SOPInstanceUID, теги пациента удаляются до сохранения.
- Реестр — цепочка: каждая запись хранит prev_hash и entry_hash = sha256(prev_hash + запись). Изменение любой записи ломает цепочку.
- Порядок проверки: нет записи → unsigned; запись испорчена / устройство отозвано / подпись не сходится → forged (с причиной); есть несовпавшие тайлы → tampered (с координатами); иначе authentic.

4.2 ИИ-щит (feature squeezing)

Снимок, как его видит модель (224×224), сравнивается с его медианно-сглаженной копией: $d = \sum |\logit(\text{оригинал}) - \logit(\text{сглаженный})|$ по 18 патологиям. Невидимый шум хрупок — сглаживание его стирает, и ответ модели резко меняется. Порог 10,4 = 99-й перцентиль на чистых снимках.

Атака	eps 0,5	eps 1	eps 2	eps 4
PGD — поймано	20% (обманула 5/30)	100%	100%	100%
FGSM — поймано	0% (обманула 3/30)	62%	87%	100%

Ложные тревоги на 450 отложенных чистых снимках: **0,9%**. Время: ≈ 50 мс. Слабые атаки (eps 0,5) проходят, но и модель они обманывают редко.

4.3 ИИ-детектив

ResNet18 (1 канал, инициализация ImageNet) обучена на CPU за 18 минут: 2000 снимков NIH + свежие синтетические подделки каждую эпоху четырёх видов. Тест — 500 снимков, которых сеть не видела.

Метрика	Значение	Оценка
AUC	0,942	✓ выше порога «экспериментальный» (0,9)
Точность	88,1%	✓
Ложные тревоги на настоящих снимках	8,4%	! приемлемо для вероятности
Поймано: стирание / узел / копирование / вставка	100% / 80% / 80% / 78%	✓
Тепловая карта попадает на подделку	4,8%	✗ уровень случайности — скрыта в UI
Ложные тревоги на детских снимках (чужой домен)	54,5%	✗ только для взрослых

4.4 Краш-тест и паспорт

Берутся снимки, которые модель считает здоровыми; к ним добавляется шум силой 0,5 / 1 / 2 / 4 пикселя (из 255). Оценка = $10 \times (1 - \text{доля изменённых диагнозов при } \epsilon_{ps} = 1)$. Результат для DenseNet121 на 50 взрослых снимках (PGD): диагноз меняется в 32% / 98% / 100% / 100% случаев, PSNR 55–45 дБ (шум не виден), **оценка 0,2 из 10**.

Паспорт: оценка $\geq 7 \rightarrow$ «разрешено»; < 7 и щит совместим ($\geq 90\%$ PGD, $\leq 2\%$ ложных тревог) $\rightarrow$ «разрешено с условиями» (щит, печать, решение врача); иначе $\rightarrow$ «не разрешено». Для DenseNet121 — **с условиями**. Паспорт хранит снимок всех цифр на момент выдачи; PDF на узбекском и русском.

5. Производительность против целей

Операция	Цель	Факт	
Печать снимка	< 50 мс	1,5 мс (PNG 512 ²), 3,8 мс (DICOM 1024 ²)	✓
Проверка снимка	< 50 мс	1,8 мс	✓
ИИ-щит	< 1 с	≈ 50 мс (первый вызов ≈ 2 с — загрузка модели)	✓
ИИ-детектив	—	≈ 50 мс + 17 мс Grad-CAM	✓
Краш-тест, 50 снимков	< 2 мин	≈ 80 с (PGD, CPU ноутбука)	✓

6. Код и тесты

Область	Объём	Комментарий
Backend: печать / проверка / ИИ / паспорт / API	255 / 104 / 541 / 432 / 388 строк	модули разделены, приватные ключи только в seal/
Скрипты (данные, калибровка, обучение, демо)	≈ 560 строк	всё воспроизводится командами из CLAUDE.md
Тесты backend	728 строк, 76 тестов	все проходят; 40 быстрых без ИИ за 3 с

Область	Объём	Комментарий
Frontend	≈ 3 800 строк TypeScript	сборка и линтер без ошибок, мок-режим без backend
История	20 коммитов, 2 автора	backend — владелец, frontend — второй разработчик

Обязательные тесты из правил проекта — все есть: round-trip печать/проверка ✓, изменение 1 пикселя ✓, подделанный реестр (сценарии В и С) ✓, атака меняет предсказание ✓, щит помечает атакованные снимки ✓. Дополнительно: формат хеша заморожен эталоном, паспорт (правила, заморозка, PDF, миграция БД), детектив, скрипт демо-подделки.

7. Безопасность и приватность

Сильные стороны

- ✓ Подпись Ed25519 и hash-chain: подделку записи без приватного ключа нельзя скрыть (тест сценария С).
- ✓ Приватные ключи не покидают модуль seal/, файлы с правами 0600, не логируются и не отдаются API.
- ✓ Теги пациента в DICOM удаляются до сохранения; только открытые датасеты; данные не уходят в облако.
- ✓ Лимит загрузки 50 МБ, проверка формата (DICOM/PNG), ИИ отключаемый (MEDSEAL_AI=0).

Риски

- ✗ **Нет авторизации.** Любой, кто видит API, может создать устройство, подписать снимок или отозвать устройство. Для демо допустимо, для пилота — обязательно (роли: аппарат / врач / администратор).
- ✗ **Ключи и реестр на одной машине.** Администратор с доступом к диску может переподписать запись. В продукте — HSM/TPM в шлюзе и внешняя копия корня цепочки (якорение).
- ✗ Ключи хранятся без шифрования; нет HTTPS; SQLite — один файл без резервных копий.
- ✗ При открытии по IP сайт виден всем в сети; публичный туннель откроет его в интернет.

8. Честные ограничения ИИ

- Детектив учился на **синтетических** подделках; на реальных подделках (Photoshop, генеративные модели) точность неизвестна.
- Тепловая карта детектива не показывает место подделки (4,8%). Место изменения точно показывает только печать.
- Всё проверено только на рентгене грудной клетки взрослых; КТ проходит печать, но ИИ-модули на КТ не проверялись.
- Одна тестируемая модель (DenseNet121). Она обучалась в том числе на NIH — возможное пересечение с нашими тестовыми снимками.
- Щит закрывает известные атаки (FGSM/PGD); адаптивная атака, знающая о щите, не проверялась.

9. Готовность к демо (по DEMO.md)

Шаг	Статус	Что нужно
1. Печать снимка	✓	устройство + data/samples/00000001_000.png, скачать файл
2. «Найди подделку»	✓	scripts.tamper_demo на скачанном файле → tampered, рамки на узле

Шаг	Статус	Что нужно
26. Детектив	✓	data/demo/fakes/*.png (демо-примеры 99–100%, общая точность 88%)
3. Атака на ИИ + щит	✓	краш-тест заранее; data/demo/00000001_000_attacked.png → щит
4. Паспорт + PDF	✓	кнопка после краш-теста
Подделка реестра (forged)	! нет в UI	показать тестами или сказать словами
Запуск на другой машине	! ручные шаги	веса детектива (≈ 20 мин обучения или копия файла), данные, .env.local
Доступ жюри со своих устройств	! риск	изоляция в Wi-Fi площадки; решение — туннель или свой роутер

10. Бизнес-модель (кратко)

Кто платит	За что	Модель
Производители ИИ	паспорт модели: краш-тест, щит, сертификат	за модель и каждую версию
Больницы	печать и проверка снимков, щит	подписка за аппарат
Минздрав	единый стандарт и мониторинг ИИ-пилотов	госконтракт
Позже	телемедицина, страховые, суды, PACS	API за проверку, лицензия

Путь: пилот в Намангане → платная сертификация ИИ → обязательный стандарт → Центральная Азия.
Цены — гипотезы, нужно проверить у менторов и врачей.

11. Рекомендации

До питча (P0)

- Прогнать сценарий демо 3 раза на ноутбуке для выступления; краш-тест PGD 50 снимков запустить заранее.
- Закоммитить скрипт tamper_demo, его тест и правку next.config.ts; решить вопрос с весами детектива (закоммитить 22 МБ или скопировать файл на демо-машину).
- Перед выступлением один раз прогнать проверку, чтобы ИИ-модели загрузились (иначе первая пауза ≈ 2 с).
- Проверить источник цифры «41% радиологов (Radiology, 2026)» из DEMO.md.
- Решить с доступом по сети: показывать с одного ноутбука или включить туннель (открывает сайт в интернет).

Если останется время (P1)

- Скрипт «демо одной командой»: устройство, подписанный снимок, tampered-копия, краш-тест, паспорт.
- Прогрев моделей при старте backend; запросы к API через сам Next.js (одна ссылка, без CORS и IP).
- Сохранять регистрацию в backend или явно пометить её как макет.
- Английский PDF паспорта (UI уже на трёх языках).

После хакатона (P2)

- Авторизация и роли; HSM/TPM для ключей; HTTPS; PostgreSQL и резервные копии; якорение корня реестра.
- Детектив на реальных подделках и генеративных снимках; рабочая локализация (occlusion / сегментация).
- Краш-тест для загружаемых моделей производителей; адаптивные атаки против щита; КТ.
- Интеграция с PACS/DICOM-шлюзом больницы; пилот с врачами и оценка на реальном потоке.

Приложение А. API (префикс /api)

Метод и путь	Назначение
GET/POST /devices · POST /devices/{id}/revoke	устройства печати, отзыв
POST /seal · GET /seal/{id}/file · GET /seals	печать, скачать подписанный файл, список
GET /ledger/check	проверка целостности цепочки
POST /verify	проверка + щит + детектив (для unsigned)
GET /models · POST /crash-test · GET /crash-test/{id} · GET /crash-tests	модели и краш-тесты
POST /passport · GET /passport/{id} · GET /passport/{id}/pdf?lang=uz ru · GET /passports	паспорта
GET /stats · GET /health	статистика, проверка работы

Приложение В. Запуск

backend: `cd backend && .venv/bin/uvicorn app.main:app --port 8000` (Swagger: /docs)

frontend: `cd by_billy/frontend && npm install && cp .env.example .env.local && npm run dev` (порт 3000)

данные и модели: `python -m scripts.fetch_samples · fetch_dataset · calibrate_shield · train_detective · make_fakes`

тесты: `.venv/bin/pytest (76) · .venv/bin/pytest -m "not ai" (40, 3 c)`

Не запускать `npm run build` при работающем `npm run dev` — обе команды пишут в `.next`, сайт начинает отдавать 404.